Dokumentasi Perubahan Autentikasi dan Otorisasi

Aplikasi Kantin Kampus - dokumentasi implementasi login, pembatasan hak akses, dan pengelolaan akun admin.

URL Aplikasi

Layanan	URL browser lokal
Frontend Vue/Vite	http://localhost:3000
Backend API	http://localhost:8000
Dokumentasi interaktif FastAPI	http://localhost:8000/docs
Health check	http://localhost:8000/health

Menjalankan aplikasi

Backend dijalankan dari folder backend dengan `uvicorn app.main:app --host 127.0.0.1 --port 8000 --reload`. Frontend dijalankan dari folder frontend dengan `npm run dev -- --host 127.0.0.1`. Vite menggunakan port 3000 dan strictPort agar alamat tidak berpindah diam-diam.

Perubahan keamanan

Aplikasi menggunakan sesi berbasis cookie HttpOnly. Token sesi tidak disimpan di localStorage/sessionStorage. Permintaan yang mengubah data dilindungi token CSRF melalui cookie dan header X-CSRF-Token. Logout mencabut sesi di backend. Endpoint data aplikasi memerlukan autentikasi; permintaan tanpa sesi ditolak.

Hak akses

Peran	Hak akses utama
user	Mengakses dan mengelola pesanan miliknya sendiri; tidak dapat mengubah status pesanan, mengelola menu, atau mengelola akun lain.
admin	Melihat semua pesanan, mengubah status pesanan, mengelola menu, serta melihat, membuat, dan menghapus akun user.

Kontrol backend dan frontend

Backend memeriksa identitas dan peran pada setiap operasi, bukan hanya menyembunyikan kontrol di frontend. User hanya dapat mengubah profilnya sendiri. Admin dapat membuat akun user dan melihat daftar akun. Admin tidak dapat menghapus akunnya sendiri. Penghapusan user mencabut token aktif dan mengalihkan pesanan user tersebut ke admin agar riwayat tetap tersimpan.

Alur administrasi akun

1. Login sebagai admin melalui panel akun frontend. 2. Buka bagian pengelolaan user. 3. Lihat daftar user, buat akun dengan username dan password awal, atau hapus akun setelah konfirmasi. 4. Setelah pembuatan/penghapusan berhasil, daftar diperbarui. API GET /users, POST /users, dan DELETE /users/{user_id} memerlukan peran admin.

Data akun demo

Database demo saat dokumentasi ini dibuat berisi satu akun admin dan tidak berisi akun user non-admin. Akun demo yang tercantum di README adalah admin dengan password 12345. Password tersebut hanya untuk latihan lokal; gunakan kredensial kuat, HTTPS, AUTH_COOKIE_SECURE=true, dan konfigurasi CORS_ORIGINS yang sesuai untuk deployment.

Validasi

Validasi terakhir: `python -m unittest discover -s tests -v` berhasil (1 workflow test); `npm run build` berhasil; frontend pada port 3000 dan dokumentasi backend pada port 8000/docs merespons HTTP 200. Workflow pengujian mencakup larangan akses lintas akun, hak admin, penghapusan akun, pencabutan sesi, dan pengalihan kepemilikan pesanan.

File implementasi terkait

Backend: app/auth.py, app/routers/users.py, app/routers/sessions.py, app/routers/menus.py, dan tests/test_auth.py. Frontend: src/services/api.js, src/components/AuthPanel.vue, src/App.vue, dan vite.config.js. Petunjuk penggunaan dan URL juga ditambahkan pada README.md tanpa menghapus konten sebelumnya.